

# THIRD-PARTY VENDOR RISK ASSESSMENT QUESTIONNAIRE (VRAQ)

Doc ID: GRC-VRAQ-2026-V1

Classification: Confidential

Alignment: ISO 27001 | NIST CSF 2.0 | SOC 2

## 1. VENDOR GENERAL INFORMATION

|                               |                                                                                                                                                       |
|-------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| Vendor Legal Name             | CloudScale Solutions Inc.                                                                                                                             |
| Product / Service Description | Enterprise SaaS Analytics Platform                                                                                                                    |
| Primary Contact Person        | Jane Doe, Chief Information Security Officer                                                                                                          |
| Contact Email & Phone         | security@cloudscale-example.com   +1 (555) 019-2831                                                                                                   |
| Assessment Date               | October 12, 2026                                                                                                                                      |
| Data Scope & Sensitivity      | <input type="checkbox"/> Public <input type="checkbox"/> Internal <input checked="" type="checkbox"/> Confidential <input type="checkbox"/> PII / PHI |

## 2. GOVERNANCE, COMPLIANCE & CERTIFICATIONS

| Ref # | Control Requirement                                                                      | Response                                                            | Evidence / Artifact Required  |
|-------|------------------------------------------------------------------------------------------|---------------------------------------------------------------------|-------------------------------|
| 2.1   | Does your organization maintain an active Information Security Management System (ISMS)? | <input checked="" type="checkbox"/> Yes <input type="checkbox"/> No | ISO 27001 Certificate Excerpt |

| Ref # | Control Requirement                                                    | Response                                                            | Evidence / Artifact Required |
|-------|------------------------------------------------------------------------|---------------------------------------------------------------------|------------------------------|
| 2.2   | Do you undergo annual independent SOC 2 audits (Type II)?              | <input checked="" type="checkbox"/> Yes <input type="checkbox"/> No | SOC 2 Type II Bridge Letter  |
| 2.3   | Do you have a designated Chief Information Security Officer (CISO)?    | <input checked="" type="checkbox"/> Yes <input type="checkbox"/> No | Org Chart Summary            |
| 2.4   | Are employee background checks performed for all production personnel? | <input checked="" type="checkbox"/> Yes <input type="checkbox"/> No | Background Check Policy      |

### 3. DATA PROTECTION & PRIVACY CONTROLS

| Ref # | Control Requirement                                                   | Response                                                            | Evidence / Artifact Required |
|-------|-----------------------------------------------------------------------|---------------------------------------------------------------------|------------------------------|
| 3.1   | Is customer data encrypted in transit using TLS 1.2 or higher?        | <input checked="" type="checkbox"/> Yes <input type="checkbox"/> No | TLS Architecture Brief       |
| 3.2   | Is customer data encrypted at rest using AES-256 or equivalent?       | <input checked="" type="checkbox"/> Yes <input type="checkbox"/> No | Encryption Policy Summary    |
| 3.3   | Does your solution support Multi-Factor Authentication (MFA) and SSO? | <input checked="" type="checkbox"/> Yes <input type="checkbox"/> No | SAML 2.0 / OIDC Config Guide |
| 3.4   | Do you maintain strict tenant isolation in multi-tenant environments? | <input checked="" type="checkbox"/> Yes <input type="checkbox"/> No | Cloud Architecture Diagram   |

### 4. VULNERABILITY MANAGEMENT & ACCESS CONTROL

| Ref # | Control Requirement                                                       | Response                                                            | Evidence / Artifact Required  |
|-------|---------------------------------------------------------------------------|---------------------------------------------------------------------|-------------------------------|
| 4.1   | Are annual third-party penetration tests conducted on production systems? | <input checked="" type="checkbox"/> Yes <input type="checkbox"/> No | Executive Summary of Pen Test |
| 4.2   | Are automated vulnerability scans performed monthly on external assets?   | <input checked="" type="checkbox"/> Yes <input type="checkbox"/> No | Vulnerability SLA Policy      |
| 4.3   | Do you enforce Least Privilege (PoLP) and Role-Based Access (RBAC)?       | <input checked="" type="checkbox"/> Yes <input type="checkbox"/> No | Access Control Matrix         |
| 4.4   | Is administrative infrastructure access protected by PAM controls?        | <input checked="" type="checkbox"/> Yes <input type="checkbox"/> No | PAM Architecture Brief        |

## 5. INCIDENT RESPONSE & BUSINESS CONTINUITY

| Ref # | Control Requirement                                                        | Response                                                            | Evidence / Artifact Required  |
|-------|----------------------------------------------------------------------------|---------------------------------------------------------------------|-------------------------------|
| 5.1   | Do you maintain a documented Incident Response Plan (IRP) tested annually? | <input checked="" type="checkbox"/> Yes <input type="checkbox"/> No | Tabletop Exercise Summary     |
| 5.2   | What is your guaranteed SLA for notifying clients after a security breach? | <b>&lt; 24 Hours</b>                                                | Breach Notification Policy    |
| 5.3   | Are production environments backed up daily with geographic redundancy?    | <input checked="" type="checkbox"/> Yes <input type="checkbox"/> No | Backup Strategy Brief         |
| 5.4   | What are your documented Recovery Time (RTO) and Point (RPO) objectives?   | <b>RTO &lt; 4 hrs</b><br><b>RPO &lt; 1 hr</b>                       | BCP / DR Plan Executive Brief |

### ASSESSMENT DETERMINATION & REMARKS

REMARKS:

- Assessor Signature: F.X. Talla Tamo

Date: Oct 14, 2026